



MUCHANGI PATRICK & ASSOCIATES

ADVOCATES OF THE HIGH COURT OF KENYA · DIGITAL TRUST ASSURANCE

— REGULATORY ANALYSIS SERIES — NO. 002

Cybersecurity Governance: Why the Board *Owens the Breach*

What directors need to own before a serious incident, not after one.

PREPARED FOR

Boards & Executive
Leadership

SECTORS

Financial Services · Healthcare ·
Technology

PUBLICATION

Knowledge Centre,
2026

CONTENTS

In This Analysis

Exec.	Executive Summary	<u>3</u>
01	The Shift from Perimeter to Governance	<u>3</u>
02	What Regulators Now Expect	<u>4</u>
03	The Cost of a Slow Board	<u>5</u>
04	Third-Party Risk Is Board Risk	<u>5</u>
05	Building a Governance-Grade Incident Response	<u>6</u>
06	What Boards Should Ask Management	<u>6</u>
—	Readiness Is the Only Guarantee Available	<u>7</u>

This analysis forms part of the Muchangi Patrick & Associates Advocates Knowledge Centre — the firm's Regulatory Analysis Series for Boards and executive leadership in Kenya.

Cybersecurity Governance: Why the Board Owns the Breach

What directors need to own before a serious incident, not after one.

EXECUTIVE SUMMARY

A ransomware note on a Monday morning does not stay an IT problem for long. Within hours it becomes a legal deadline, a client-relations crisis and a boardroom question. In Kenya, as elsewhere, the technical failure is rarely what damages an institution most — the governance failure around it is.

Boards are increasingly expected to demonstrate that they understood their organisation's cyber exposure before an incident, not merely that they responded competently after one. Regulators, insurers and clients are beginning to ask the same question in different words: who was watching, and what did they see?

This analysis sets out why cybersecurity has become a governance discipline rather than a purely technical one, and the questions every Board should be able to answer before the next serious incident — not during it.

01

The Shift from Perimeter to Governance

For a long time, cybersecurity was framed as a wall — firewalls, antivirus, intrusion detection — built and maintained by an IT department the Board rarely needed to hear from directly. That framing has not aged well.

The institutions that suffer the worst outcomes from a cyber incident are rarely those with the weakest technology; they are the ones whose governance could not tell them, quickly enough, that something had gone wrong. A modern cyber incident moves through an organisation the way a legal or reputational crisis does — because that is exactly what it becomes within hours.

Most successful cyberattacks exploit weaknesses in oversight, not weaknesses in technology.

02

What Regulators Now Expect

Kenya's data protection framework requires organisations to maintain appropriate security safeguards, and to notify affected parties and the regulator when personal data has been compromised. The precise mechanics continue to be refined through guidance and enforcement practice, but the direction is unambiguous: regulators expect organisations to detect incidents quickly, assess them honestly, and report them without the kind of delay that looks, in hindsight, like concealment.

The Office of the Data Protection Commissioner has, in recent practice, shown less patience for organisations that discover a breach and spend weeks deciding what to do about it. A Board that only learns of an incident once the narrative is already public has, in effect, ceded control of its own crisis.

The Cost of a Slow Board

Detection speed and decision speed are different problems, and most institutions underinvest in the second. A well-instrumented system can flag an intrusion in minutes; a Board that has never rehearsed what happens next can still take days to authorise a public response. That gap — between knowing and acting — is where reputational damage compounds.

WHERE DETECTION FAILS

- Alerts routed to an inbox nobody monitors
- No defined threshold for escalating to executives
- Logs retained too briefly to reconstruct events

WHERE RESPONSE FAILS

- No pre-approved holding statement
- Unclear authority to notify the regulator
- Legal counsel engaged only after the story breaks

Third-Party Risk Is Board Risk

Very few serious breaches originate inside the walls of the organisation that ultimately answers for them. Cloud providers, payment processors, outsourced call centres and SaaS vendors routinely hold as much sensitive data as the institution itself, often with governance the Board has never reviewed. A vendor's weak password policy becomes, eventually, the Board's problem.

- Has every material vendor been assessed for its own security governance, not just its service quality?
- Do contracts specify breach notification timelines from vendor to client, not only client to regulator?
- Is there a current inventory of which vendors hold what category of data?

Building a Governance-Grade Incident Response

A credible incident response capability is less about tooling and more about clarity: who is the designated incident lead, who authorises public communication, which legal partner is on retainer before an incident rather than found afterward, and how often the plan is actually rehearsed rather than simply filed.

- A named incident response lead with clear authority, independent of the technology team
- A tested communication protocol, including a pre-drafted holding statement
- A retained external legal and forensic partner, engaged before an incident, not during one
- A Board reporting cadence that does not wait for the quarterly cycle

What Boards Should Ask Management

Every Board should be able to put the following questions to management, and expect a considered answer:

- | | |
|----|--|
| 01 | How would we know, today, if a serious breach were underway? |
| 02 | Who has the authority to notify the regulator, and how quickly could they act? |
| 03 | When did we last test our incident response plan, and what did we learn? |
| 04 | Which third-party vendors hold data that would embarrass us if lost? |
| 05 | Is legal counsel retained and briefed before an incident, or found during one? |
| 06 | What is our realistic time-to-detection, and is that acceptable? |
| 07 | Does the Board receive cybersecurity reporting on a fixed cadence, or only after something goes wrong? |

CONCLUSION

Readiness Is the Only Guarantee Available

Cybersecurity governance is not a guarantee against incidents — no Board can offer that. It is a guarantee that when an incident happens, the organisation already knows what to do, who decides, and how fast it can move. That readiness is what regulators, clients and insurers are increasingly measuring, whether or not it has been formally asked for yet.

BOARD CONSIDERATION

“If a serious breach happened tonight, would your Board know before your customers did?”

If that question gives you pause, an independent review of your incident governance — not just your technology — may be the more urgent gap to close.

M

About the Author

Muchangi Patrick & Associates Advocates is a Kenyan law firm specialising in Digital Trust Assurance, data protection, technology law, AI governance and regulatory advisory. We help Boards understand, govern and continuously improve how their organisations manage information, technology, artificial intelligence and legal risk.

Request an Executive Briefing

We help leadership teams understand, govern and continuously improve Digital Trust through structured, evidence-based advisory engagements.

Pinetree Plaza, Nairobi · 0722 878 607 · consult@dataprivacyadvocates.co.ke